

Pickle Rick

Plataforma: TryHackMe

Dificuldade: Fácil

Data de Resolução: 01/04/2026

Autor: Mateus Reis Bastos

Matrícula: 241008513

Sumário

1. Visão Geral
 2. Reconhecimento
 3. Exploração
 4. Escalada de Privilégios
 5. Conclusão
-

1. Visão Geral

A máquina "Pickle Rick" apresenta um cenário de exploração de vulnerabilidades web e escalada de privilégios em ambiente Linux, com o objetivo final de coletar três ingredientes. A superfície de ataque inicial explorada consistiu na descoberta de credenciais de login (usuário "R1ckRul3s" e senha "Wubbalubbadubdub") através da enumeração de diretórios (/robots.txt) e inspeção do código-fonte, permitindo o acesso ao painel de comandos.

Após o acesso, a exploração seguiu para a utilização desse painel de execução de comandos remotos, onde foi necessário contornar a sanitização de black list (substituindo `cat` por `less`) para obter os primeiros ingredientes. Por fim, a escalada de privilégios para root foi garantida pela exploração de uma configuração insegura do sudo, que permitia a execução do comando `sudo su` sem a necessidade de senha, garantindo os privilégios máximos para coletar o último ingrediente.

2. Reconhecimento

Para começar procuramos por portas abertas na máquina e achamos a porta 80 aberta, indicando HTTP e, consequentemente, uma aplicação Web. Na página inicial, foi encontrado o nome de usuário "R1ckRul3s" ao inspecionar os elementos. Ao explorar os assets, foram usados os nomes dos arquivos para testar possíveis diretórios do site, o que levou à descoberta de /portal.php e, consequentemente, da página login.php. Além disso, o arquivo /robots.txt (achado pelo gobuster) continha o texto "Wubbalubbadubdub", que foi testado com sucesso como a senha para acesso.

Figura 1: Identificação das portas abertas do servidor.

```
(kali@kali)-[~/vpn]
$ nmap -T4 10.67.169.252
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 20:17 -0400
Nmap scan report for 10.67.169.252
Host is up (0.13s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

Figura 2: Exploração de diretórios com o Gobuster.

```
(kali@kali)-[~/vpn]
$ gobuster dir -u 10.67.169.252 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.67.169.252
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

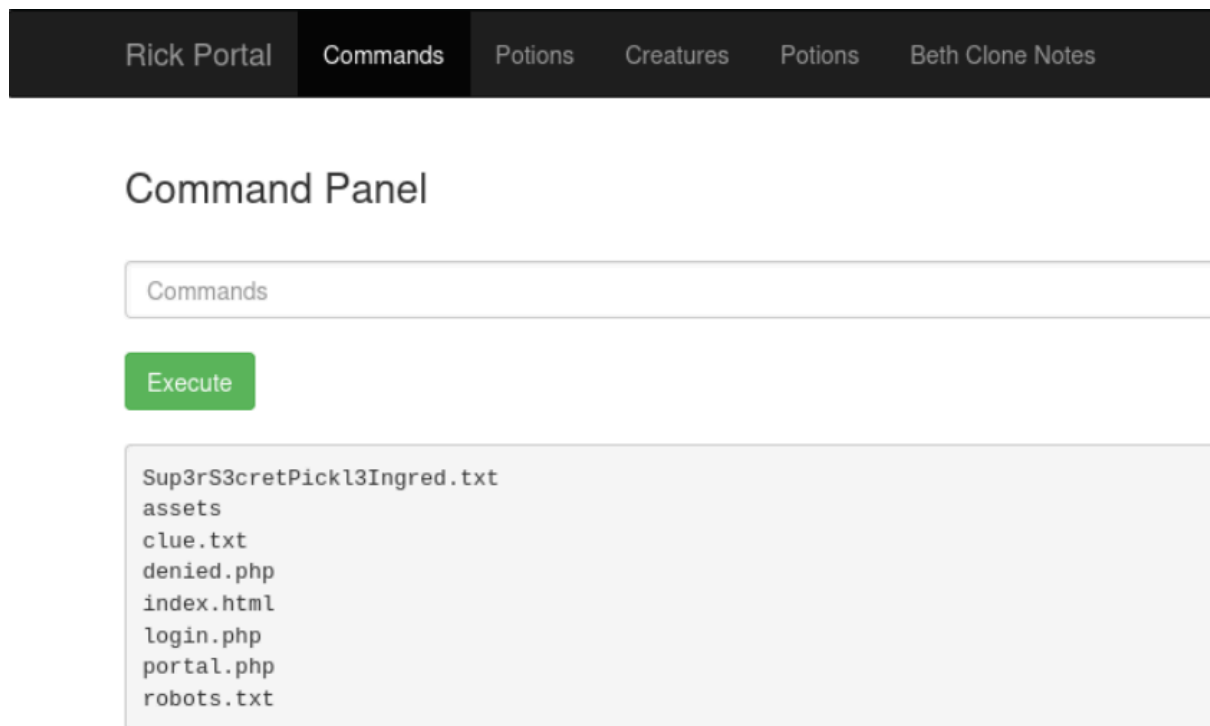
.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
assets (Status: 301) [Size: 315] [→ http://10.67.169.252/assets/]
index.html (Status: 200) [Size: 1062]
robots.txt (Status: 200) [Size: 17]
server-status (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)

Finished
```

3. Exploração

Ao fazer login com sucesso, foi encontrada uma página com um painel de comandos que permitia a execução de comandos na máquina alvo. Inicialmente, o comando `ls` listou alguns arquivos `.txt` que poderiam conter um dos ingredientes. No entanto, a tentativa de usar `cat <nomedoarquivo>` para mostrar o conteúdo resultou em um bloqueio, indicando a presença de uma sanitização de comandos que impossibilitava a execução de comandos que estavam na *black list*.

Figura 3: Painel de comando com o resultado do comando `ls`.



Buscando uma alternativa, o comando `less` foi utilizado para substituir o `cat` e conseguiu mostrar o conteúdo dos arquivos `.txt`, revelando o primeiro ingrediente. Para encontrar o segundo ingrediente, foi listado o diretório raiz (`ls /`), seguido pelo diretório `/home`, onde apareceram os usuários `rick` e `ubuntu`. Listando o que havia dentro do diretório `rick`, o arquivo “`second ingredients.txt`” foi encontrado e lido usando o comando `less /home/rick/"second ingredients.txt"`.

4. Escalada de Privilégios

Para encontrar o terceiro e último ingrediente, foi necessária a escalada de privilégios para `root`. O comando `sudo -l` mostrou que não havia necessidade de senha para acesso de superusuário, permitindo que o privilégio fosse obtido com um simples `sudo su`. Com o acesso de superusuário, foi possível navegar pelo diretório `/root`. Usando `sudo ls /root`, o arquivo de texto `3rd.txt` foi encontrado, contendo o último ingrediente.

5. Conclusão

A invasão da máquina dependeu da enumeração de diretórios que revelou credenciais de acesso válidas (“`R1ckRul3s`” e “`Wubbalubbadubdub`”) escondidas no arquivo `/robots.txt`, garantindo o acesso

a um painel de execução de comandos remotos. O *bypass* da *black list* de comandos foi crucial para a exploração inicial, exigindo a substituição de *cat* por *less*. A escalada de privilégios foi direta e eficiente, exigindo apenas a identificação de uma configuração vulnerável do *sudo* (que permitia *sudo su* sem senha), demonstrando os riscos da configuração excessiva e insegura de permissões de superusuário no sistema.